Práctica 1: Recogida de información pasiva

Técnicas de Hacking - Universidad Europea

Estudiante: Gonzalo Revuelta

Objetivo: Auditoría OSINT Repsol S.A.

Índice de Contenidos

1. Investigación de Registros DNS (1.0 pt) 2
    1.1. Función de los registros 2
    1.2. Reconocimiento Pasivo vs. Activo 2
2. Auditoría OSINT: Repsol S.A. (4.0 pts) 2
    2.1. Fase 1: Perfilado y Modelo de Negocio (2.1) 2
    2.2. Fase 2: El hilo conductor (DNS a Infraestructura) 2
    2.3. Fase 3: Mapeo de subdominios 2
    2.4. Fase 4: Google Dorking - Buscando el error humano 3
3. Conclusiones 5
Bibliografía 6

1. Investigación de Registros DNS (1.0 pt)

El análisis DNS es la piedra angular del reconocimiento. Según [3], entender estos registros permite mapear la superficie de ataque sin interactuar con el objetivo.

1.1. Función de los registros

- A / AAAA: IPs del servidor.
- MX: Servidores de correo (clave para identificar Office 365).
- TXT: Seguridad y validación (SPF/DMARC).
- CNAME / NS / SOA / PTR: Alias, autoridad y resolución inversa.

1.2. Reconocimiento Pasivo vs. Activo

La consulta es pasiva si usamos herramientas como **DNSDumpster** o servidores públicos como el `8.8.8.8` de Google. Se vuelve activa si intentamos una transferencia de zona (AXFR) directamente al servidor de Repsol, ya que nuestra IP quedaría registrada en sus auditorías de seguridad.

2. Auditoría OSINT: Repsol S.A. (4.0 pts)

2.1. Fase 1: Perfilado y Modelo de Negocio (2.1)

Repsol es una energética del IBEX 35. Mi investigación comenzó analizando su negocio: venden carburante y energía a millones de clientes y dependen de proveedores como Microsoft. Como indica [1], el perfilado es vital para saber qué buscar después.

2.2. Fase 2: El hilo conductor (DNS a Infraestructura)

Al ver que Repsol es una empresa global, mi «historia» de investigación me llevó a mirar sus registros MX. Descubrí que usan Microsoft Outlook Protection. Esto me dio la pista: si el correo es Microsoft, probablemente sus portales de acceso también lo sean.

Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP
repsol-com.mail.protection.outlook.com	52.101.73.1 mail-am3pr04cu00501.inbound.protection.outlook.com	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56452
repsol-com.mail.protection.outlook.com	52.101.68.36 mail-db5pr02cu00104.inbound.protection.outlook.com	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56504
repsol-com.mail.protection.outlook.com	52.101.68.39 mail-db7pr03cu00607.inbound.protection.outlook.com	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56385
repsol-com.mail.protection.outlook.com	52.101.73.15	ASN 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56280

Figura 1: Hallazgo de infraestructura de correo mediante DNS pasivo.

2.3. Fase 3: Mapeo de subdominios

Con el mapa de subdominios, visualicé la inmensa red de Repsol. Cada subdominio es una puerta potencial que investigué de forma pasiva.

Figura 2: Grafo de activos digitales expuestos de Repsol S.A.

2.4. Fase 4: Google Dorking - Buscando el error humano

Siguiendo la metodología de [2], usé Google para buscar lo que el DNS no muestra:

1. Dork de Documentos: Busqué PDFs confidenciales.

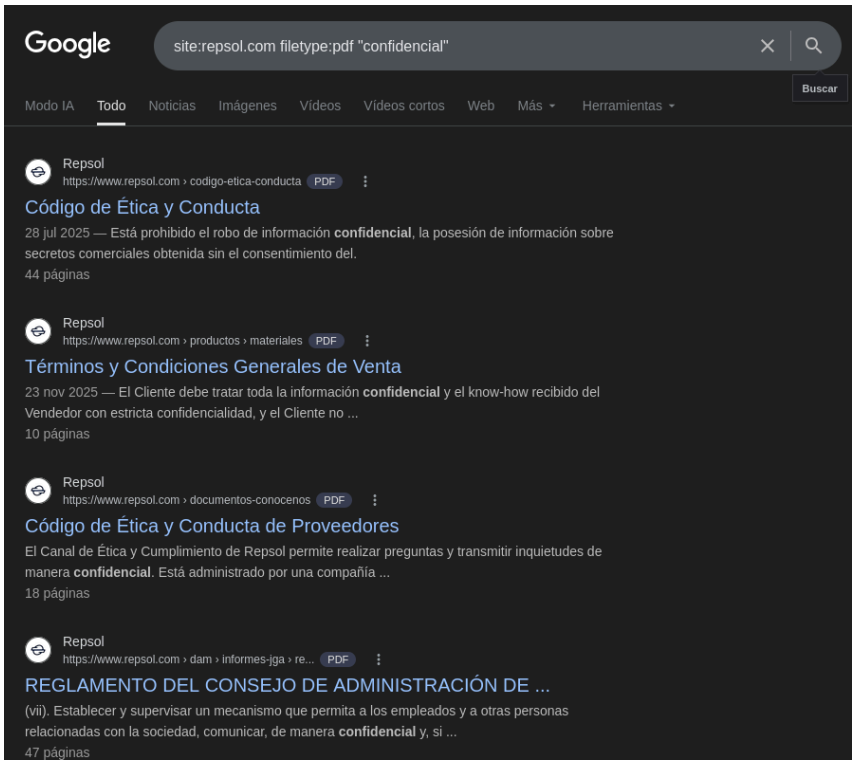

Figura 3: Dork 1: Documentación interna indexada.

2. Dork de Login: Busqué portales de acceso Azure/Microsoft.

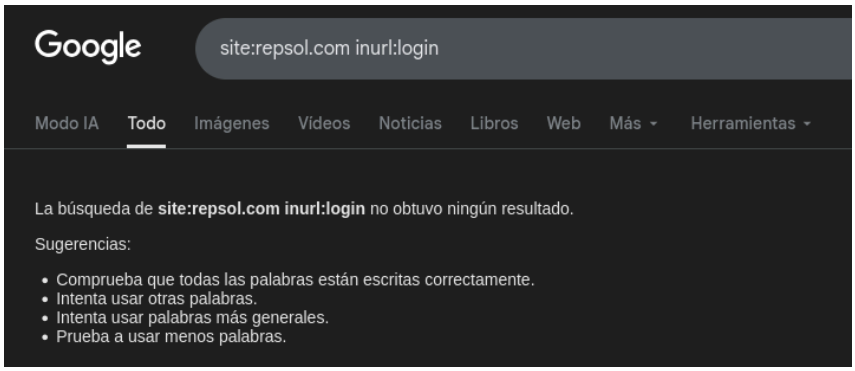

Figura 4: Dork 2: Paneles de autenticación expuestos.

3. Dork de Directorios: Busqué carpetas abiertas («Index of»).

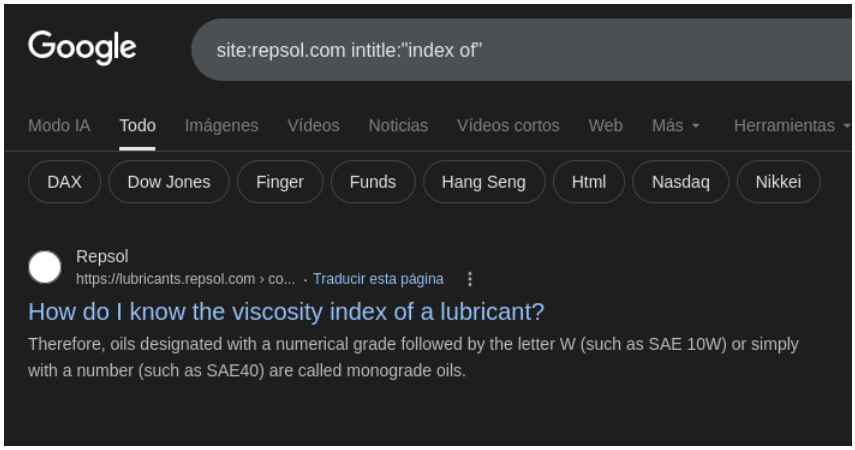

Figura 5: Dork 3: Servidores con listado de directorios activo.

3. Conclusiones

Esta investigación demuestra que el OSINT es una cadena lógica: el modelo de negocio me llevó al DNS, y este a los Dorks. Todo se hizo de forma pasiva, cumpliendo la ética de la práctica.

Bibliografía

Glassman, A., & Kang, M. (2012). Open source intelligence methods and tools. *Journal of US Intelligence Studies*.

Long, J., Gardner, B., & Brown, J. (2011). *Google hacking for penetration testers*. Elsevier.

Petersen, A. L., & Stowe, G. (2020). *DNS Security: Defending the Domain Name System*. O'Reilly Media.